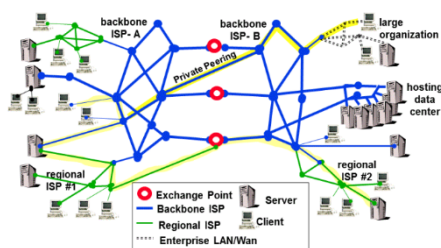
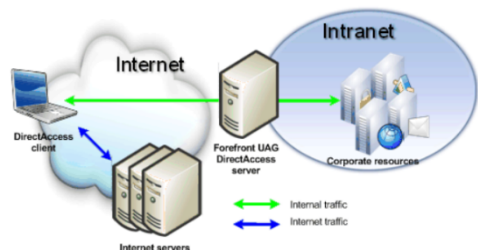


מצגת 1 – מבוא למרחב הקיברנטי ואבטחת מידע

1. מרחב הסייבר (The Cyberspace Landscape)

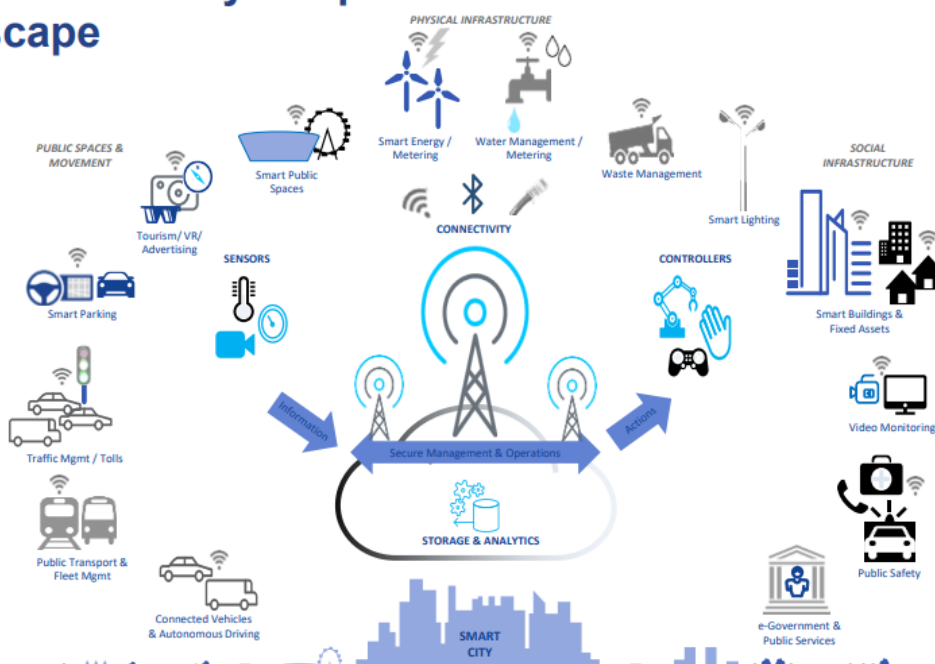
מרחב הסייבר הוא סביבה דיגיטלית מקושרת הכוללת רשתות מחשוב, תשתיות תקשורת ומערכות מידע המאפשרות אינטראקציה בין אנשים, ארגונים ומכונות. ניתן לחלק את מרחב הסייבר לארבע שכבות מרכזיות:

- **השכבה הפיזית:** כל רכיבי החומרה המוחשיים – כבלים אופטיים תת-ימיים, נתבים, מרכזי נתונים (Data Centers) ולוויינים.
- **השכבה הלוגית:** הפרוטוקולים והתוכנות המאפשרים את העברת הנתונים – TCP/IP, DNS, מערכות הפעלה, שירותי ענן ו-APIs.
- **השכבה החברתית:** האנשים, הזהויות הדיגיטליות, קהילות מקוונות והתנהגות המשתמשים.
- **שכבת הממשל:** חוקים, רגולציות, תקנים בינלאומיים (כגון ISO 27001) והסכמים בין מדינות.



הסייבר בעולם הפיזי (ערים חכמות): מערכות דיגיטליות מוטמעות כיום בכל היבט של החיים המודרניים, מה שמגדיל את "שטח התקיפה". זה כולל אנרגיה חכמה (מונים חכמים), תחבורה מקושרת (רכבים אוטונומיים), מבנים חכמים (מערכות מיזוג ובקרה), וממשל אלקטרוני (שירותים לאזרח).

Introduction to Cyberspace Landscape



2. מודל ה-CIA

זהו המודל הבסיסי שכל בקרת אבטחה נשענת עליו:



- **סודיות (Confidentiality):** הבטחה שהמידע נגיש רק למי שמורשה אליו.
 - כלים מרכזיים: הצפנה (AES-256), בקרת גישה, אימות רב-שלבי (MFA) וסיווג נתונים.
 - **לא חשוב במקרים שהמידע גם ככה יהיה ציבורי** (פרסומים ב-Ynet)
- **שלמות (Integrity):** הבטחה שהמידע מדויק, עקבי ולא שונה או זויף ללא הרשאה.
 - כלים מרכזיים: פונקציות Hash, חתימות דיגיטליות (PKI) ובקרת גרסאות.
 - **שאלות מנחות לניתוח:** מי שינה את המידע? מתי? באיזו הרשאה? האם אנו יכולים לזהות את השינוי? האם אנו יכולים לשחזר למצב קודם?
 - **לא חשוב למערכות של זמן אמת** (כמו שיחות זום – זה אולי יקרטע לשנייה אבל השיחה תמשיך במקרה של אובדן חבילת מידע)
- **זמינות (Availability):** הבטחה שהמערכות והמידע יהיו נגישים למשתמשים מורשים כל הזמן.
 - כלים מרכזיים: יתירות (Redundancy), איזון עומסים (Load Balancing) והגנה מפני התקפות DDoS.
 - **לא חשוב במקרים שהמידע הוא סטטי** (מערכות Offline, תהליכי אימות)
- 85% מהארגונים מתמודדים עם גישה לא מורשית לנתונים באופן קבוע. 70% מתקריות הפגיעה בשלמות המידע קשורות לטעות אנוש וחוסר תשומת לב.

אתגרים ביישום ה-CIA:

קשיים באיזון בין אבטחה לנוחות שימוש, מחסור במשאבים ותקציב, ניהול מורכבות המערכות וצורך בהדרכת עובדים מתמדת.

3. אמון ומהימנות (Trusted vs. Trustworthy)

- **Trusted (מערכת "נאמנת"):** רכיב שהמערכת חייבת להסתמך עליו כדי לאכוף את מדיניות האבטחה שלה. **אם הוא נפרץ – כל המערכת קורסת.** (דוגמה: ליבת מערכת ההפעלה).
- **Trustworthy (מערכת "מהימנה"):** רכיב שיש לנו **ראיות והוכחות** (בדיקות, הסמכות, אימות פורמלי) לכך שהוא אכן מאובטח ונקי מפגמים. (דוגמה: שבב TPM או רכיב חומרה עם הסמכת FIPS).

השאיפה היא להבטיח שכל רכיב שאנו "סומכים" עליו (TRUSTED) יהיה גם "מהימן" (TRUSTWORTHY)

4. טרמינולוגיית תקיפה (Attack Ontology)

שרשרת הסיכון:

1. **פגיעות (Vulnerability):** חולשה במערכת (קוד, הגדרה או התנהגות אנושית).
2. **איום (Threat):** גורם או אירוע פוטנציאלי שעלול לנצל את הפגיעות (האקרים, אסונות טבע).
3. **מתקפה (Attack):** הפעולה המכוונת של ניצול הפגיעות.
4. **פשרה (Compromise):** המצב שבו האבטחה הופרה והתוקף הצליח במשימתו.



גורמי איום מרכזיים: פושעי סייבר (מניע כלכלי), שחקני מדינה (ריגול וחבלה), אקטיביסטים (מניע אידיאולוגי) ואיומים פנימיים (עובדים סוררים או רשלנים).

5. שטח תקיפה מול וקטור תקיפה

- **שטח תקיפה (Attack Surface):** סך כל נקודות הכניסה שדרכן תוקף יכול לנסות לחדור (פורטים פתוחים, ממשקי API, עובדים, כניסות פיזיות).
 - האסטרטגיה: צמצום שטח התקיפה על ידי סגירת שירותים מיותרים ויישום גישת "מינימום הרשאות".
- **וקטור תקיפה (Attack Vector):** הנתיב הספציפי או השיטה שבה משתמש התוקף כדי לנצל פגיעות (פשינג, הזרקת קוד SQL, ניצול Zero-Day).

מגמות בולטות (2024-2026): שימוש בבינה מלאכותית ליצירת פשינג מתוחכם ודיפ-פייק, התפתחות תוכנות כופר למודלים של "כופר כשירות" (RaaS), והתקפות על שרשרת האספקה של התוכנה.

6. הבדל בין אבטחת מידע לסייבר

תחום	מיקוד מרכזי	מוקד הפעילות והגורמים המעורבים
אבטחת מידע	הגנה על המידע ומערכות המידע כדי לשמר את מודל ה-CIA	מידע דיגיטלי, תהליכים, הרשאות, מדיניות ותאימות
סייבר	הגנה על השימוש במרחב הקיברנטי מפני מתקפות ופגיעות.	רשתות, נקודות קצה, שירותים חשופים, זיהויות, יריבים ותגובה לאירועים.

7. אתגרי אמון

- **ממשקי משתמש (User Interfaces):** עיצובים מורכבים עלולים לבלבל משתמשים, ושימושיות ירודה עלולה להוביל לחוסר אמון.
- **חוסר שקיפות בתפעול המערכת:** תהליכים נסתרים מפחיתים את ביטחון המשתמש. כדי לסמוך על המערכת, משתמשים צריכים שקיפות מלאה.
- **באגים בתוכנה:** גורם לפריצות אבטחה, קוד שכתוב לא נכון מוביל לשגיאות וניתנות לניצול ופריצה
- **הגדרות שגויות:** יכולות לחשוף נקודות תורפה בקוד, הגדרות ברירות מחדל יכולות להיות לא מאובטחות

8. פשרה/פריצה (Compromise) - אינדיקטורים לפריצה (IOCs)

סמנים לזיהוי שמערכת נפרצה (Indicators of Compromise):

- תעבורת רשת יוצאת חריגה ליעדים לא מוכרים.
- הסלמת הרשאות חשבון בלתי צפויה או יצירת חשבונות מנהל חדשים.
- דפוסי התחברות חריגים (זמנים יוצאי דופן, מיקומים גיאוגרפיים שונים, ניסיונות כושלים).
- התראות של כלי אבטחה או השבתה של סוכני אנטי-וירוס/EDR.

9. משטח תקיפה מול וקטור תקיפה (כלל אצבע)

- **משטח (Surface):** איפה אפשר לנסות לחדור (Where you can try).
- **וקטור (Vector):** איך מנסים לחדור בפועל (How you try in practice).
- תוקפים קודם כל ממפים את המשטח, ורק אז בוחרים את הווקטור המתאים.

בחירת הוקטור
המתאים



מיפוי המשטח

1. מהי נזקה?

- **נזקה (Malware - Malicious Software) - כל תוכנה או קוד שנועדו לחדור למערכת מחשב, להזיק לה או לבצע בה פעולות ללא אישור המשתמש.**

מטרות עיקריות:

- **גניבת נתונים:** גניבת סיסמאות, מידע פיננסי ופרטי זהות.
- **שיבוש שירותים:** השבתת רשתות (כמו התקפות DDoS) ופגיעה באמון הלקוחות.
- **נזק למערכת:** השחתת קבצים, פגיעה בביצועים והשבתה מלאה של המחשב.
- **ריגול:** מעקב שקט אחר פעילות המשתמש, הקלטת הקשות מקלדת (Keylogging) והדלפת מידע רגיש.

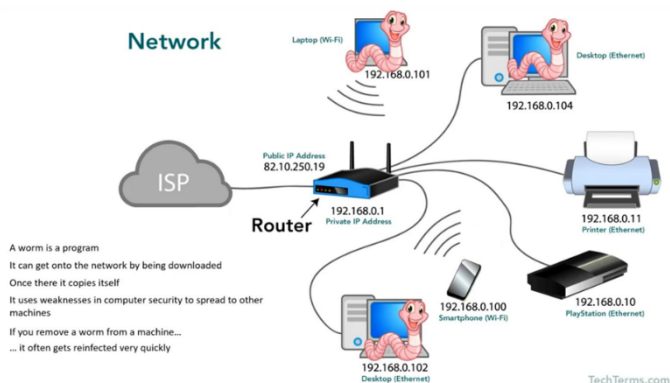
2. וירוסים (Viruses)

- **מאפיינים:** תוכנה הנצמדת לקובץ "מארח" (Host) ודורשת אינטראקציה אנושית (כמו פתיחת קובץ) כדי להפעיל את עצמה ולהפיץ את הקוד.

סוגי וירוסים נפוצים:

- **מבוססי מסמכים (למשל .DOC):** מופעלים כאשר המשתמש מאשר הפעלת "מאקרו" (Macros).
- **מבוססי קבצי הרצה (למשל .EXE):** מופעלים ברגע שהמשתמש מריץ את התוכנה הנגועה.
- **שיטות הפצה:** קבצים מצורפים במייל, כונני USB, הורדות מאתרים לא אמינים והנדסה חברתית.
- **השפעה:** השחתת נתונים, צריכת משאבי מערכת וגניבת מידע.

3. תולעים (Worms)



- **מאפיינים:** בניגוד לוורוס, התולעת היא תוכנה עצמאית (Standalone) שלא זקוקה לקובץ מארח. רצה על מערכות הפעלה
- **הפצה אוטונומית:** התולעת משתכפלת ומפיצה את עצמה ברשתות באופן אוטומטי על ידי ניצול חולשות אבטחה, ללא צורך בפעולת משתמש.
- **נזקים:** גורמת להאטה משמעותית בתקשורת הרשת עקב צריכת רוחב פס גבוהה, ועלולה להדביק אפי מחשבים בדקות ספורות.

4. השוואה: וירוס מול תולעת

תכונה	תולעת (Worm)	וירוס (Virus)
צורת הפצה	עצמאית דרך הרשת	דורשת פעולת משתמש
תלות במארח	לא זקוקה לקובץ מארח	חייבת קובץ או תוכנה מארחת
מהירות הפצה	מהירה מאוד (דקות)	איטית יותר (תלויה במשתמש)
דוגמאות	WannaCry, SQL Slammer	ILOVEYOU, Melissa

5. סוגי התקפות ונוזקות נוספות

- תוכנת כופר (Ransomware)**
התקפה שבה הנוזקה מצפינה את קבצי המשתמש ודורשת תשלום (בדרך כלל בביטקוין) עבור מפתח הפענוח.
- **תהליך:** שליחת מייל פשינג ← לחיצה על קישור/קובץ ← הצפנת נתונים ← הצגת מסך דרישת כופר.

- Adware פרסומות**
תוכנה המציגה פרסומות קופצות (Pop-ups) והצעות מפוקפקות ללא הפסקה. המטרה היא לייצר רווח ליוצרי הנוזקה מכל לחיצה של המשתמש.

- ג. דלת אחורית (Backdoor) וטרויאנים**
התקפות המאפשרות לתוקף שליחה מרחוק של פקודות למחשב הקורבן.

- **Dropper**: קובץ "מטען" (כמו מסמך Word) שברגע פתיחתו מוריד ומתקין את הנוזקה האמיתית במערכת.
- **RAT (Remote Access Trojan)**: מאפשר לתוקף להשתמש במצלמה, לגנוב קבצים ולבצע Keystroke logging.

ד. חטיפת סשן (Session Hijacking)
גניבה או ניבוי של "טוקן" (Token) של התחברות כדי לקבל גישה לחשבונות המשתמש בשרתים ללא צורך בסיסמה.

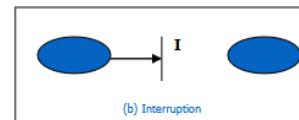
6. אנטומיה של התקפה (מבוסס על תרשימים)

1. **זיהוי מטרות**: התוקף אוסף כתובות מייל מרשתות חברתיות.
2. **חדירה**: שליחת מייל "מלכודת" עם מסמך נגוע או קישור זדוני.
3. **הפעלה**: המשתמש פותח את הקובץ, מה שמפעיל קוד זדוני (כמו PlugX או Ghost RAT) שיוצר קשר עם שרת השליטה והבקרה (C&C) של התוקף.
4. **התפשטות**: התוקף מתחזה לקורבן ושולח הודעות נגועות נוספות לאנשי הקשר שלו כדי להרחיב את הפגיעה.

מצגת 3 – איומי סייבר

1. סוגי מתקפות בסיסיים על זרימת מידע

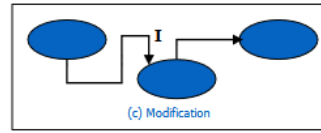
1. **הפרעה/השבתה (Interruption)**: פגיעה בזמינות. פגיעה ברציפות שירות או משאב כך שאינו מגיב או מגיב באיחור חריג.



- דוגמה: התקפות DDoS, הצפת Endpoint בשאלות LLM.

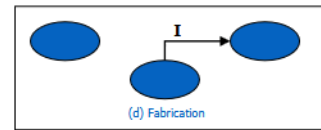
2. **שינוי/שיבוש (Modification):** פגיעה בשלמות. שינוי לא מורשה של נתונים, מודלים, תצורה או קוד בדרך או במנוחה.

- דוגמה: שינוי קבצי אימון (Data/Model poisoning), הזרקת פקודות (Prompt injection).



3. **זיוף/המצאה (Fabrication):** פגיעה באותנטיקציה/נאותות. יצירת נתונים, אירועים או זהויות שלא התקיימו והכנסתם כגורם לגיטימי.

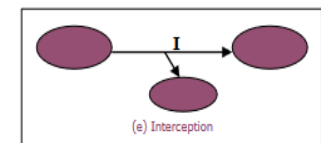
- דוגמה: התחזות לשירות באמצעות API key גנוב



- בשינוי אנחנו עורכים משהו קיים ובזיוף אנחנו יוצרים משהו חדש

4. **יירוט/האזנה (Interception):** פגיעה בסודיות. גישה לא מורשית לתוכן או מטא-דאטה בזמן מעבר או במנוחה ללא שינוי גלוי.

- דוגמה: יירוט בקשות דרך פרוקסי.



2. סיווג התקפות כללי (Cyber Attack Classifications)

1. **התקפה אקטיבית (Active Attack):** ניסיון לשנות משאבי מערכת או לשבש פעילות, מה שעלול להוביל לדלף מידע או תקלות הדורשות אמצעי אבטחה מיידיים.

2. **התקפה פסיבית (Passive Attack):** התמקדות באיסוף מידע ללא השפעה על משאבי המערכת, כגון האזנה לתקשורת, העלולה להוביל לגישה לא מורשית למידע רגיש.

3. **התקפה משולבת (Hybrid Attack):** שילוב אלמנטים משני הסוגים, המאפשר לתוקפים לנצל חולשות תוך הישגות מתחת לרדאר.

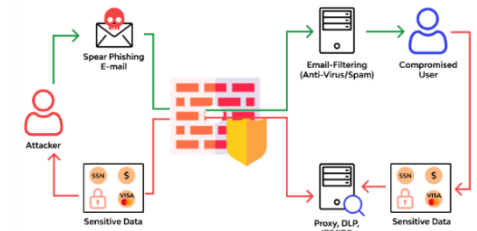
3. חשיפה לא מורשית (Unauthorized Disclosure)

איום הממוקד בפגיעה בעקרון הסודיות (Confidentiality). התוצאה היא חשיפת מידע רגיש או גישה לתוכן שאינו מיועד לצפייה על ידי גורמים חיצוניים.

3.1 סוגי התקפות מרכזיים:

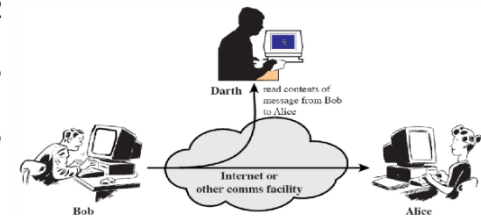
1. **חשיפה (Exposure):** נתונים רגישים משוחררים ישירות לישות לא מורשית.

- **דוגמה:** דליפת קבצים מ-S3 ציבורי או לוגים שחושפים מפתחות API
- **התמודדות:** שימוש ב-DLP (Data Loss Prevention)



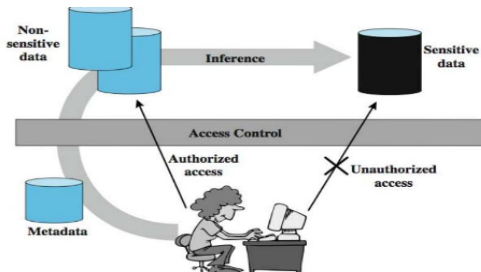
2. **יירוט (Interception):** ישות לא מורשית ניגשת לנתונים רגישים במעבר.

- **דוגמה:** התקפת אדם-באמצע (MITM) או קריאת נתונים ברשת פתוחה
- **התמודדות:** שימוש בהצפנת TLS (Transport Layer Security).



3. **הסקה (Inference):** גזירת מידע רגיש מתוך מידע שאינו רגיש (כמו ניתוח מטא-דאטה או הצלבת נתונים).

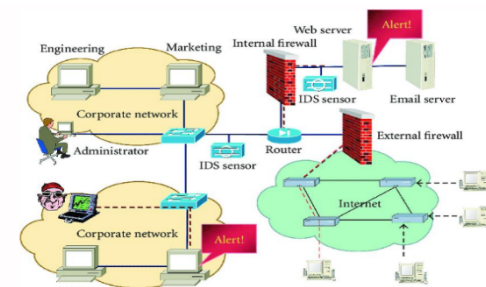
- **דוגמה:** גזירת מידע אישי דרך מטא-דאטה חשוף או דרך לוחות בקרה
- **התמודדות:** שימוש באנונימיזציה, הגבלת חשיפת מטא-דאטה



4. **התערבות (Intrusion):** עקיפת מנגנוני אבטחה קיימים לשם השגת גישה למידע.

- **דוגמה:** גורם לא מורשה שעוקף את האבטחה של המערכת כדי להשיג גישה

- **התמודדות:** אימות רב שלבי (MFA), עיקרון הרשאות מינימליות.



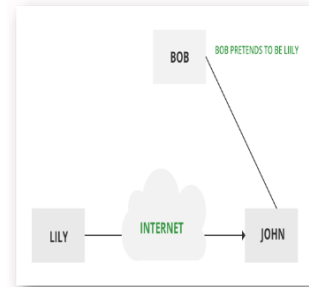
4. הונאה (Deception)

איום הממוקד בפגיעה בשלמות המידע או המערכת (Integrity). המטרה היא להטעות את המשתמש או את המערכת ולגרום להם להאמין במידע שגוי.

4.1 סוגי התקפות מרכזיים:

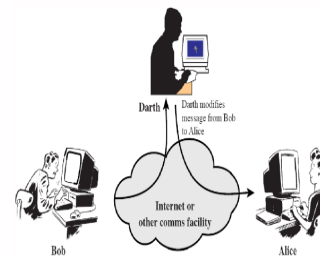
1. **התחזות (Masquerade):** תוקף המתחזה לישות מורשית כדי לגנוב הרשאות או לשלוח פקודות בשם המערכת.

- **דוגמה:** מתקפת פשינג, חטיפת סשן או שימוש ב-API Key גנוב של שירות LLM.
- **התמודדות:** אימות רב-שלבי (MFA), תחלופת מפתחות תדירה ושימוש בטוקנים קצרי-מועד.



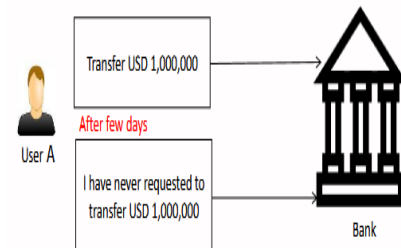
2. **זיוף (Falsification):** הכנסת מידע כוזב למערכת כדי לעוות תוצאות או החלטות.

- **דוגמה:** הזרקת פקודות זדוניות לסוכן AI או שינוי נתונים בזמן העברתם בצינור המידע.
- **התמודדות:** שימוש בחתימות דיגיטליות, ולידציה מחמירה למידע נכנס ואילוצי כתיבה.



3. **דחייה (Repudiation):** הכחשת אחריות לפעולה שבוצעה

- **דוגמה:** משתמש המכחיש שביקש להעביר כספים, או שינוי מודל AI ללא עקבות וללא לקיחת אחריות.
- **התמודדות:** יצירת לוגים מרכזיים חסיני-שינויים (Tamper-evident logs), חותמות זמן קריפטוגרפיות ואישור אנושי (HITL).



5. שיבוש (Disruption)

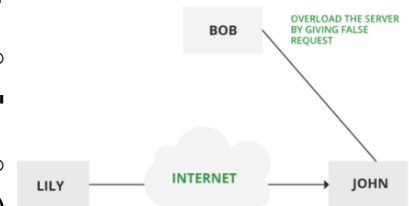
איום הממוקד בפגיעה בזמינות המערכת (Availability). הפעולה גורמת למערכת להפסיק לתפקד, להאט באופן חריג או לאבד נתונים.

5.1 סוגי התקפות מרכזיים:

1. **שליטת יכולת (Incapacitation):** מניעת פעולת מערכת על ידי השבתת רכיב

◦ **דוגמה:** תוכנות כופר (Ransomware) שמצפינות מידע, מקריסות חומרה, או יצירת עומס מכון שמשתק כוח עיבוד של מודל.

◦ **התמודדות:** שמירת גיבויים לא-מקוונים (Offline backups), הגבלת קצב בקשות (Rate-limiting) והרחבה אוטומטית (Autoscaling).



2. **השחתה (Corruption):** פגיעה בנתונים או בפונקציות המערכת.

◦ **דוגמה:** הרעלת נתוני אימון (Data Poisoning) ב-LLM או התקנת עדכוני תוכנה פגומים.

◦ **התמודדות:** חתימה על מערכי נתונים (Signed datasets), בדיקות איכות מחמירות, ואילוצי מערכת (Constraints).

3. **חסימה (Obstruction):** מניעת העברת שירותים או גישה למערכת.

◦ **דוגמה:** מתקפות מניעת שירות (DDoS) שמציפות את ה-API של המערכת, או תשישות משאבים (Resource Exhaustion).

◦ **התמודדות:** חומת אש לאפליקציות (WAF), ניתוב עומסים באמצעות CDN, ומנגנוני Circuit breakers

6. תפיסה בכוח / שימוש לרעה (Usurpation)

איום הממוקד בשימוש במערכת בניגוד למטרותיה המקוריות, תוך השגת שליטה על משאבים.

6.1 סוגי התקפות מרכזיים:

1. **ניכוס פסול (Misappropriation):** השתלטות על משאבים לוגיים או פיזיים ללא הרשאה

◦ **דוגמה:** גניבת מודלים קנייניים על ידי משתמש פנים, או שימוש במפתחות ענן שדלפו לצורך כריית קריפטו.

◦ **התמודדות:** בקורות גישה מחמירות, ניהול זכויות גישה (DRM), התראות על הוצאות חריגות, ואכיפת מכסות שימוש (Quotas).

2. **שימוש לרעה (Misuse):** ניצול של הרשאות קיימות לביצוע פעולות

- **דוגמה: סוקן** Al עם כלים והרשאות רחבים שמבצע פעולות הרסניות, או ניצול לרעה של הרשאות ניהול
- **התמודדות:** עבודה בסביבות מבודדות, מבדקי גישה קבועים, וניטור שוטף לזיהוי חריגות ושימוש במנגנון אנומליות.

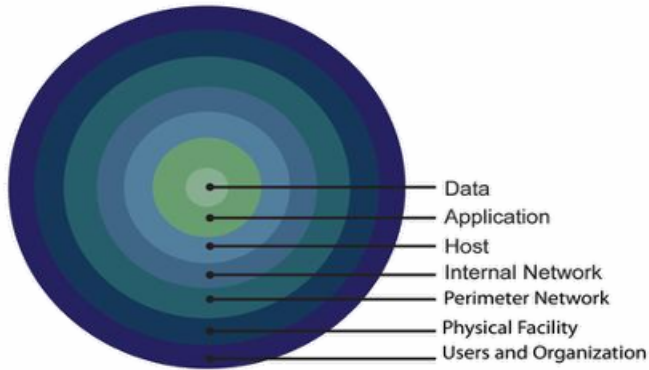


7. טבלת סיכום: מיפוי איומים לעקרונות CIA

סוג איום	סודיות (Confidentiality)	שלמות (Integrity)	זמינות (Availability)	אחריותיות (Accountability)
חשיפה לא מורשית	גבוהה	נמוכה	בינונית	גבוהה
הונאה	בינונית	גבוהה	בינונית	גבוהה
שיבוש	בינונית	נמוכה	גבוהה	נמוכה
תפיסה בכוח	גבוהה	בינונית	נמוכה	בינונית

1. עקרון ההגנה לעומק (Defense in Depth)

גישת ההגנה לעומק היא אסטרטגיה המבוססת על יצירת מספר (7) שכבות אבטחה, כך שאם שכבה אחת נפרצת, יש שכבות נוספות שמגינות על המערכת. השכבות השונות, מהפנימית לחיצונית, כוללות:



1. נתונים (Data)
2. אפליקציה (Application)
3. מארח (Host)
4. רשת פנימית (Internal Network)
5. רשת היקפית (Perimeter Network)
6. מתקן פיזי (Physical Facility)
7. משתמשים וארגון (Users and Organization)

2. אבטחת היקף (Perimeter Security)

המודל המסורתי של אבטחת רשתות מבוסס על יצירת הפרדה בין הרשת הפרטית לרשת הציבורית. רכיבי ההגנה בהיקף הרשת כוללים:

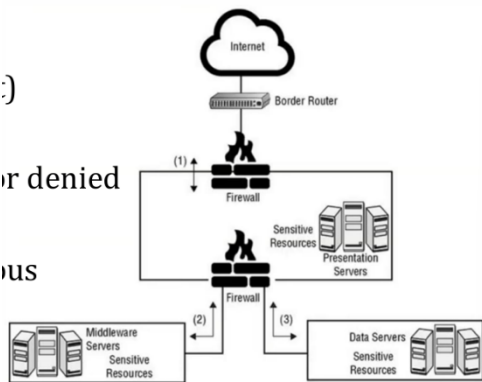
- **נתבי גבול (Border Routers):** הנתב האחרון שנמצא בשליטת הארגון לפני היציאה לרשת לא מהימנה (כמו האינטרנט).

- **חומות אש (Firewalls):** מחליטות איזו תעבורה תורשה להיכנס או תידחה.

- **מערכות זיהוי ומניעת חדירות (IDS/IPS):** מערכות אזעקה המזהות אירועים זדוניים ומתריעות עליהם, ומספקות הגנה אוטומטית ללא התערבות מנהל רשת.

- **רשתות וירטואליות פרטיות (VPN):** יצירת הפעלת רשת מוגנת על גבי ערוץ לא מוגן.

- **אזורים מפורזים (DMZ):** רשת קטנה המספקת שירותים ציבוריים (לרוב אינה מוגנת על ידי חומת האש הפנימית).



3. חומות אש (Firewalls) - מודל שכבה 3

חומת אש פועלת כמערכת שנועדה למנוע גישה בלתי מורשית לרשת פרטית. היא מבודדת את הרשת הפנימית של הארגון מהאינטרנט (External Network), ומאפשרת מעבר של מנות נתונים מסוימות תוך חסימה של אחרות.

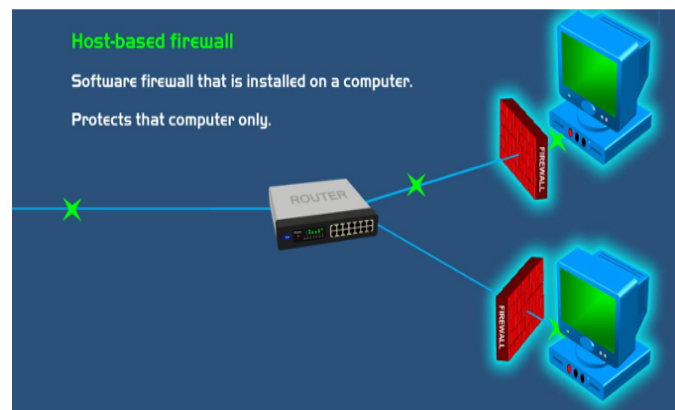
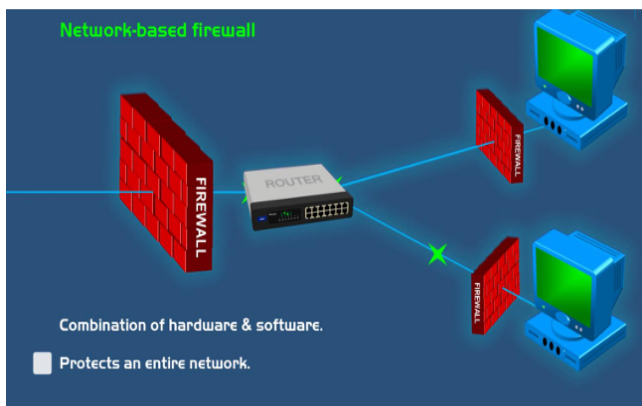
3.1 ארבעת תפקידי חומת האש:

1. ניטור תעבורת הרשת.
2. בחינת מנות נתונים בזמן אמת (Inspecting Data Packets).
3. ויסות תעבורה (אפשר או חסימה) ואכיפת חוקים.
4. הגנה מפני איומים חיצוניים כגון נזקות, האקרים והתקפות מניעת שירות (DoS).

3.2 שני סוגי חומות האש:

1. **מבוססת מארח (Host-based firewall):** תוכנה המותקנת על מחשב בודד ומגנה עליו בלבד.
2. **מבוססת רשת (Network-based firewall):** שילוב של חומרה ותוכנה המגן על רשת שלמה.

- מבחינת פריסה, ניתן למצוא חומות אש עצמאיות (Stand-alone), חומות אש מובנות בנתבים, וחומות אש בענן.



4. סינון חבילות (Packet Filtering) ורשימות גישה (ACL)

חומת אש מסוג סינון חבילות מחליטה האם להעביר או להפיל מנות נתונים בהתבסס על:

- כתובת IP מקור



Permission	IP Address	Protocol	Destination	Port
ALLOW	ANY	TCP	ANY	80
ALLOW	ANY	TCP	ANY	25
ALLOW	ANY	TCP	ANY	110
DENY	ANY	UDP	ANY	23
DENY	ANY	TCP	ANY	3389

- כתובת IP יעד
- פורט
- מבוקש ופרוטוקולים (כגון TCP, UDP).

רשימות בקרת גישה (ACL - Access Control Lists): רשימות המכילות חוקים והרשאות לגבי מי מורשה לגשת למשאבים. קיימות שתי גישות מרכזיות:

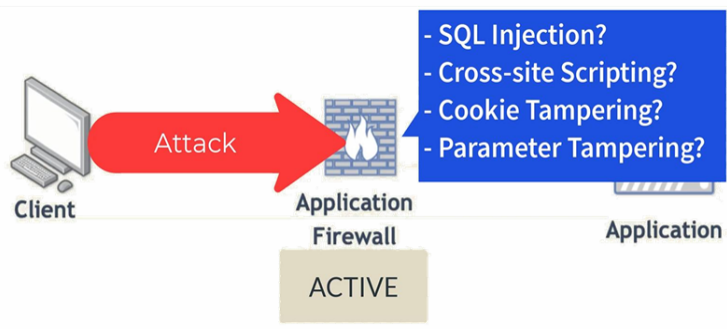
- **מניעה מרומזת (Implicit Deny):** הגישה נדחית כברירת מחדל, אלא אם קיים כלל המאפשר אותה במפורש (Whitelist).
- **אישור מרומז (Implicit Allow):** הגישה מותרת כברירת מחדל, אלא אם קיים כלל השולל אותה במפורש (Blacklist).

5. חומות אש ברמת האפליקציה (WAF & Layer 7)

- **Proxy Firewall (Application Gateways):** חומת אש הפועלת כשער בין רשתות עבור אפליקציות ספציפיות, ומסננת תוכן ברמת הפרוטוקולים כמו HTTP, FTP ו-SMTP.
- **WAF (Web Application Firewall):** ממוקדת בהגנה מפני התקפות על יישומי רשת, כגון הזרקות Scripting, SQL חוצה אתרים (XSS), ושינויים זדוניים בפרמטרים או עוגיות (Cookie Tampering).

השוואה בין Layer 3 ל-Layer 7:

- **שכבה 3 (Network Layer):** מסננת לפי כתובות IP ופורטים. בעלת ביצועים גבוהים ומהירות סינון מהירה, מתאימה לאיומים כלליים ובקרת גישה בסיסית.
- **שכבה 7 (Application Layer):** בוחנת את תוכן מנות הנתונים (Deep Packet Inspection). היא איטית יותר, אך הכרחית להגנה על אפליקציות רגישות ולאיומים מורכבים כמו XSS או SQLi.

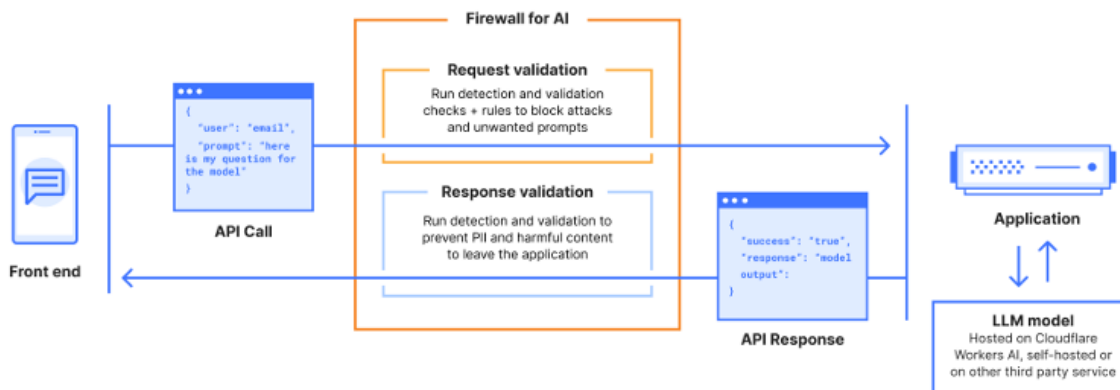


	Layer 3 firewalls	Layer 7 firewalls
Traffic filtering	Based on IP addresses and ports	Examines contents within data packets
Performance	High throughput; handles large volumes of traffic	Lower throughput due to deep packet inspection
Speed of inspection	Fast; simple filtering based on addresses & ports	Slower; detailed analysis of packet contents
Security focus	General threats; basic access control	Complex, application-targeted threats
Use case	Suitable where speed and volume are critical	Needed for sensitive applications needing deep inspection
Typical threat mitigation	Blocks threats based on source/destination info	Mitigates threats exploiting application vulnerabilities like SQL injections, XSS

המשתמש הקצה למודל. תפקידן:

- **אימות בקשות (Request validation):** חסימת התקפות (כמו Prompt injection) ופרומפטים לא רצויים.
- **אימות תגובות (Response validation):** מניעת זליגת נתונים (PII) ותוכן פוגעני מהאפליקציה החוצה.

בשונה מחומת אש של הדור הבא (NGFW) המתמקדת בפרוטוקולי רשת וחסמת נזקות מסורתיות, חומת אש ל-AI מתמקדת בטקסטים בשפה טבעית, סינון פרומפטים ובקרת API.

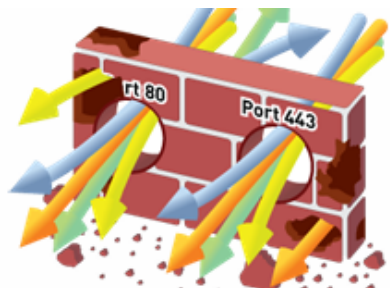


Capability	AI Firewall	Next-Generation Firewall (NGFW)
Focus Area	LLMs, AI applications, GenAI workflows	Network layer, application protocols, threat blocking
Content Inspection	Natural language inputs/outputs, AI-specific logic	Packets, ports, known malware, protocol headers
Key Features	Prompt filtering, output redaction, API control	IDS/IPS, antivirus, WAF, URL filtering
Deployment Layer	App/API/model layer	Network perimeter, routers, VPN endpoints
Threat Types	Prompt injection, data leaks, model abuse	DDoS, malware, phishing, ransomware
Target Users	AI/ML developers, security architects, SOC teams	Network admins, infrastructure and IT security teams
Example Use Case	Protecting a GenAI-powered customer support chatbot	Blocking phishing and malware from a remote office

7. פריסת חומות אש - סביבות מסורתיות לעומת ענן

- **מודל מסורתי (Traditional Data Center):** מאופיין בתכנון היקפי קבוע (Fixed perimeter), בו אכיפת המדיניות מתבצעת בגבולות מרכזיים עם חומות אש חומרתיות.
- **מאפייני ענן (Cloud characteristics):** סביבות הענן הופכות את המודל המסורתי ללא מספק, עקב שימוש מרובה בספקי ענן, גדילה דינמית (Auto-provisioning) ועומסי עבודה קצרי מועד (Serverless functions), היוצרים פער באבטחה (Security gap).

1. חומת אש רגילה לא מספיקה



- קיימות כיום התקפות שעוקפות בקלות של חומת אש קלאסית, כמו ניצול פרוצדורות באפליקציות או שימוש בטכניקות של מנהור (Tunneling).
- קיים איום תמידי של פעילות פנימית זדונית או רשלנית (Insider Activity) מתוך הרשת עצמה.
- ארגונים רבים מחויבים לעמוד בדרישות רגולטוריות מחמירות הדורשות פיקוח מחמיר יותר, כמו בתחומי הבנקאות והבריאות.
- קיים צורך קריטי לזהות אירועים בזמן אמת ולקבל יכולות של חקירת אירועים (Forensics).

2. ההבדל בין מערכת זיהוי למערכת מניעה

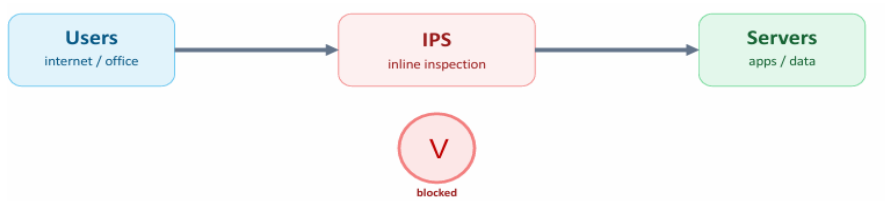
2.1 מערכת לזיהוי חדירות (IDS)

מטרתה העיקרית היא **להתריע**. המערכת מנטרת תעבורה, יומנים ואירועים, מזהה פעילות חשודה ומייצרת התראות **מבלי לחסום את התעבורה בפועל**. המערכת יושבת **מחוץ לנתיב הראשי** וסורקת עותק של המידע המכונה גם **תעבורה פסיבית**, ולכן היא מצוינת להשגת נראות רשתית ללא הפרעה לעסק.



2.2 מערכת למניעת חדירות (IPS):

מטרתה **לזהות ולחסום איומים באופן מיידי**. המערכת ממוקמת פיזית **בנתיב התעבורה הראשי (Inline)**, ולכן היא מסוגלת לעצור מנות נתונים פגומות (Packets) זדוניות או לחסום משתמשים פוגעניים. החיסרון הוא **שזיהויים שגויים עלולים להוביל לחסימת משתמשים לגיטימיים** ופגיעה בזמינות השירות.



3. סוגי התראות ואתגרי כוונון

- התאמת המערכות לארגון סובבת סביב יצירת איזון במטריצת הבלבול (Confusion Matrix) כדי להימנע מטעויות בזיהוי.

- **חיובי שגוי או התראת שווא (False Positive):** המערכת מתריעה ומודיעה על התקפה, למרות שמדובר בפעילות לגיטימית. עודף של התראות כאלו מוביל לעייפות התראות אצל המפעילים (Alert Fatigue).

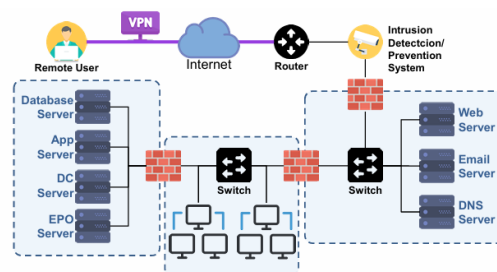
- **שלילי שגוי (False Negative):** המערכת אינה מזהה התקפה אמיתית ואינה מתריעה עליה. זהו המצב המסוכן ביותר לארגון כיוון שהאיום חודר פנימה באין מפריע.

- המטרה של המגנים היא להגביר את הדיוק מבלי לאבד את כיסוי האבטחה, דבר שנעשה על ידי כונון (Tuning) שוטף המבוסס על רגישות הנכסים הארגוניים.

4. קטגוריות של IDS

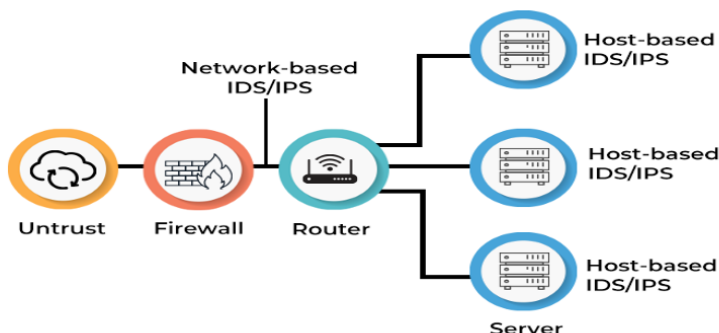
4.1 מערכת מבוססת רשת (NIDS)

ממוקמת בנקודות אסטרטגיות של הרשת, כמו מתגים ונתבים, ומנטרת את כל התעבורה שעוברת בה. היא מאפשרת להגן על תתי-רשתות שלמות ולספק תמונה רחבה על המתרחש ברשת.



4.2 מערכת מבוססת מארח (HIDS)

מותקנת כסוכן תוכנה ישירות על גבי תחנות עבודה או שרתים. היא מנטרת פעילות פנימית בתוך המערכת עצמה, כגון תהליכי זיכרון, שינויים בקבצים ורישומים בתוך יומני פעילות (Logs).



(Kno

שיטה המתבססת על התאמה מול מאגר חתימות זדוניות מוכרות מראש. היתרון הוא מהירות רבה ודיוק גבוה למול התקפות ידועות, אך החיסרון המהותי הוא חוסר היכולת לזהות איומים חדשים שטרם הוכנסו למאגר (התקפות Zero Day).

5.2 זיהוי מבוסס התנהגות או אנומליה (Behavior Based)

שיטה שלומדת מהי ההתנהגות הנורמלית והתקינה של הארגון או המשתמש, ומתריעה על כל סטייה מהנורמה. היתרון הוא כיסוי נרחב המאפשר לאתר התקפות חדשות לחלוטין, אך החיסרון הוא נטייה לייצר כמות גדולה יותר של התראות שזוא בעקבות שינויים לגיטימיים בפעילות העסקית.



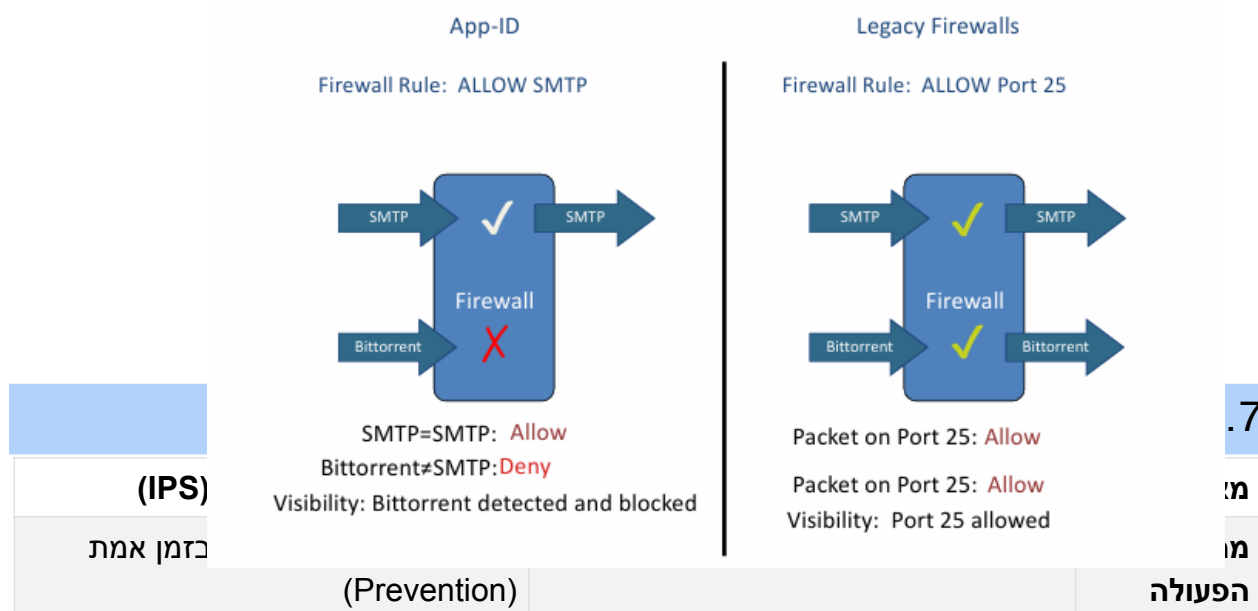
6. הדור הבא של חומות האש

6.1 האתגר מול חומות אש מיושנות

מערכות מסורתיות בודקות ומאשרות תעבורה בהתבסס על פרוטוקולים ומספרים של פורטים (Ports) בלבד. **תוקפים מודרניים למדו להסוות איומים** ולתקשר דרך פורטים חוקיים ולגיטימיים, כך שחומת האש הישנה מאפשרת להם להיכנס בחופשיות.

6.2 המעבר לדור החדש (NGFW)

פתרונות חדשים או, הנקראים לרוב פתרונות אבטחה מאוחדים (UTM), **מאגדים שכבות הגנה שונות למכשיר חכם אחד**. הם מסוגלים לזהות איזו אפליקציה בדיוק עוברת ברשת בעזרת מזהה אפליקציות (App-ID), ללא תלות בפורט בו היא משתמשת, ובכך להעניק שליטה פרטנית ומדויקת על כל פעולה ברשת הארגונית.



תצורה ומיקום	מחוץ לנתיב הראשי, קוראת העתק תעבורה (Passive)	בתוך נתיב התעבורה הראשי של הארגון (Inline)
סכנה לתפקוד	סיכון נמוך מאוד עד אפסי לזמינות הרשת	עלולה בטעות לחסום תעבורה ארגונית תקינה

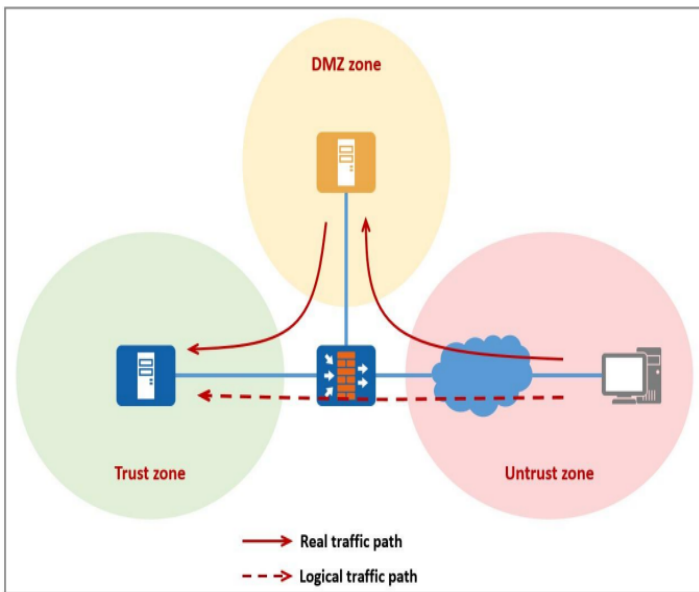
מצגת 6 – DMZ Design & Governance

1. הגדרות יסוד ומטרות של אזור מפורז (Basics & DMZ Goals)

- **אזור מפורז (Demilitarized Zone):** מקטע רשת מבודד הממוקם בין הרשת הפנימית, המאובטחת לבין רשת חיצונית שלא מאובטחת, במטרה לספק שכבת הגנה נוספת לארגון.

- **מטרות מרכזיות (Core Goals):** הגבלת חשיפה לשירותים הכרחיים בלבד, אילוץ תעבורה לעבור בנקודות ביקורת צרות (Choke points), וצמצום נתיבי תנועה רוחבית (Lateral movement) א עבר הרשת הפנימית.

- **מה האזור אינו מהווה (Non-Goals):** לא תחליף לאבטחת אפליקציות, לא "פח אשפה" לשירותים מסוכנים, ולא מהווה עדות למודל אפס אמון (Zero Trust) בפני עצמו.



2. עקרונות הנדסת מערכת

- **הרשאה מינימלית (Least Privilege):** כל מערכת, שירות ומשתמש מקבלים אך ורק את ההרשאות המינימליות הנדרשות לפעולתם.
- **הפרדת תפקידים (Separation of Duties):** אין לאפשר למנהל רשת בודד לשלוט בכל השכבות. צוות התקשורת מנהל חומות אש, צוות פיתוח מנהל שרתים, וצוות אבטחה מבקר את כולם.
- **כשל מאובטח (Fail Secure):** מערכות חייבות להפוך לחסומות כברירת מחדל בעת תקלה (Deny on failure). אם חומת אש קורסת, היא צריכה לעצור כל תעבורה ולא לאפשר מעבר חופשי.
- **הגנה לעומק (Defense in Depth):** שימוש במספר בקורות אבטחה בלתי תלויות, כך שאם אחת נכשלת, האחרות ימשיכו להגן על המערכת.
- **תיווך מלא (Complete Mediation):** כל בקשת גישה חייבת להיבדק מחדש. אסור להסתמך על אישורים שמורים (Cached credentials) או נתיבים עוקפים.
- **חיסכון במנגנונים (Economy of Mechanism):** שמירה על עיצוב רשת פשוט כמה שאפשר, בגלל שמערכות מורכבות מגדילות את שטח התקיפה (Attack surface).

3. מדריך מיקום שירותים (Service Placement Guide)

- **שירותים המיועדים לאזור המפורז (DMZ Hosts):** כל שרת שדורש גישה לאינטרנט או שמקבל חיבורים לא מהימנים מבחוץ. רשימה זו כוללת שרתי רשת באמצעות פרוקסי הפוך (Web servers), שערי דואר אלקטרוני (Email gateways), שרתי שמות חיצוניים (External DNS), ומאזני עומס (Load balancers).

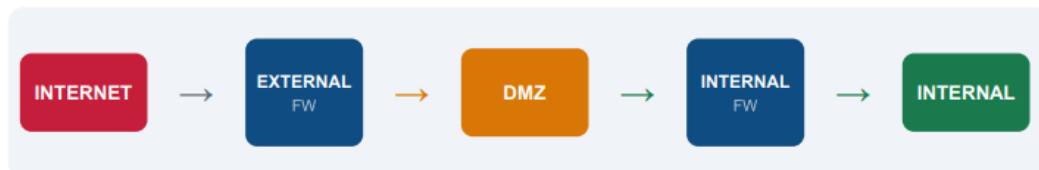
- **שירותים האסורים באזור המפורז (Keep Internal):** שירותים המכילים מידע רגיש ומהווים תשתיות ליבה של הארגון. רשימה זו כוללת בסיסי נתונים מכל סוג (Databases), מערכות ניהול זהויות (Active Directory), שרתי קבצים (File servers), וכן מערכות איסוף יומנים (SIEM).

4. טופולוגיות וארכיטקטורות נפוצות (DMZ Architectures)

- **חומת אש בודדת (Single Firewall):** ארכיטקטורה זולה ופשוטה הכוללת מכשיר אחד עם שלוש רגליים (Three-Legged). החיסרון הגדול שלה הוא היותה נקודת כשל בודדת (SPOF), שכן פריצה אליה פותחת גישה מלאה לארגון.



- **רשת משנה מסוננת (Screened Subnet):** התקן הארגוני המחמיר, העושה שימוש בשתי חומות אש נפרדות (פנימית וחייצונית) שהאזור המפורז "כלוא" ביניהן. מומלץ להשתמש ביצרנים שונים (Vendor Diversity) לכל חומת אש כדי למנוע ניצול של פגיעות אפס ימים (Zero-day) שתפיל את שתיהן.



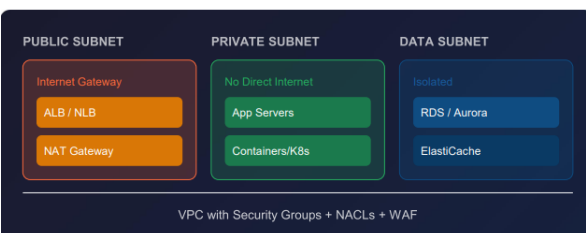
• ארכיטקטורת תלת-שכבות (Three-Tier DMZ):

ארכיטקטורה מחמירה המבוססת על שלוש שכבות מופרדות (רשת, אפליקציה, נתונים) שביניהן חוצצות חומות אש נפרדות. החיסרון הגדול שלה הוא העלות הגבוהה והמורכבות הניהולית הרבה (High Complexity and Cost), שכן היא דורשת תחזוקת חוקים קפדנית שמונעת דילוג בין שכבות, ומתאימה בעיקר לארגונים גדולים המטפלים במידע רגיש (כמו בנקים).



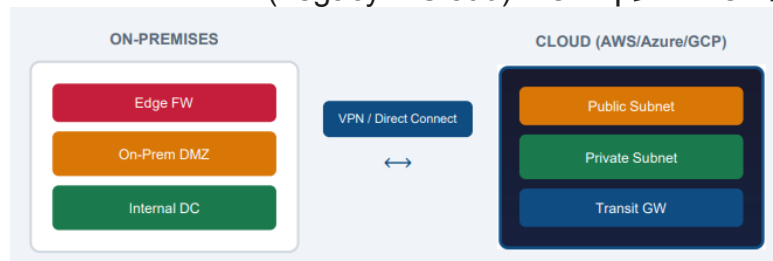
• ארכיטקטורת ענן (Cloud-Native):

בניית אזור מפורז בענן, אזור מפורז מיושם באמצעות חלוקה לרשתות וירטואליות (VPC) ותתי-



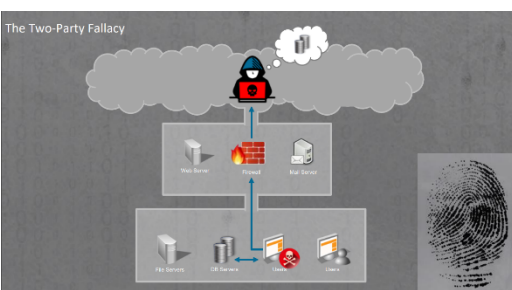
רשתות פומביות ופרטיות (Public/Private Subnets), המוגנות על ידי קבוצות אבטחה (Security Groups) ורשימות בקרת גישה (NACLs).

- **ארכיטקטורת ענן היברידית (Hybrid Cloud DMZ Architecture):** ארכיטקטורה המשלבת בין מערכות מקומיות בארגון לבין עומסי עבודה בענן ציבורי, ומחייבת תחזוקה של אזור מפורז בשני המיקומים תוך ניהול מדיניות אבטחה אחידה וחיבור מוצפן ביניהם. החיסרון הגדול שלה הוא המורכבות הניהולית והעלות הגבוהה, לצד הסכנה שבמתן אמון אוטומטי בחיבור המקשר (VPN) בין שתי הסביבות, שכן היא דורשת יישום בקורות קפדניות משני צידי הקו וניהול ריכוזי, ומתאימה בעיקר לארגונים מבוססים המשלבים מערכות תשתית ישנות יחד עם שירותי ענן חדשים (Legacy + Cloud).



5. התפתחות הפרימטר והכשלים המודרניים (Perimeter) (Fallacies & Evolution)

- **התרחבות היקף ההגנה (Birth of Perimeter Security):** עם השנים נאלצו להוסיף עוד ועוד מערכות הגנה על קו התפר (Perimeter) כגון מערכות למניעת זליגת מידע (DLP), שערי רשת מאובטחים (SWG), שירותי סינון דואר, ומערכות איתור חדירות (IDS/IPS) כדי להתמודד עם פתיחת הרשת לאינטרנט ולמשתמשים מרחוק (VPN).



- **כשל שני הצדדים (The Two-Party Fallacy):** התפיסה השגויה לפיה האויב נמצא רק בחוץ והרשת הפנימית בטוחה. הנחה זו מאפשרת לתוקפים לנוע בחופשיות (Lateral Movement) בתוך הרשת הפנימית ברגע שהם עוקפים את חומת האש או מדביקים מחשב נייד של עובד.
- **מודל אפס אמון (Zero Trust):** אינו מחליף את האזור המפורז, אלא מרחיב אותו כך שכל מקטע רשת וכל משתמש נבדקים באופן רציף, מבלי להסתמך רק על גבולות הפרימטר ההיסטוריים.

6. פגיעויות והגדרות שגויות באזור המפורז (DMZ) (Misconfigurations)

- **סיכון גבוה (High Risk):** חיבור ישיר מהאזור המפורז לבסיס הנתונים הפנימי, רשת שטוחה (Flat DMZ) ללא הפרדה פנימית, וכן שרתים המצורפים לדומיין הארגוני הראשי (Domain-joined).
- **סיכון בינוני (Medium Risk):** שיתוף של סיסמאות הרשאה בין האזור המפורז לרשת הפנימית, חוקיות המאפשרת יציאה חופשית (Outbound any-any), והשארת שירותים ללא עדכוני אבטחה (Unpatched) החשופים לאינטרנט.

7. טבלת השוואת ארכיטקטורות אבטחה

סוג ארכיטקטורה	ציון אבטחה	רמת מורכבות	עלות	ייעוד מומלץ ושימוש
חומת אש בודדת	3/5	נמוכה	\$	עסקים קטנים וסביבות פיתוח
חומת אש כפולה	5/5	בינונית	\$\$	תקן לחברות אנטרפרייז
שלוש שכבות	5/5	גבוהה	\$\$\$	ארגונים פיננסיים ושירותי בריאות
טבעי לענן	5/5	בינונית	\$\$	חברות מבוססות ענן
סביבה היברידית	4/5	גבוהה	\$\$\$	ארגונים עם שילוב ישן וחדש